Marco teórico

Cinco conceptos, en este orden, que después se aplican en el caso práctico.

1

Usuarios y grupos

Quién es quién

2

Permisos de archivos

Qué puede hacer cada uno

3

RBAC

Permisos por rol

4

sudo y setuid

Privilegios controlados

5

Auditoría

Quién hizo qué

Usuarios y grupos

El sistema operativo identifica a cada persona con un usuario y decide todos los permisos según esa identidad.

`UID y GID`

Cada usuario tiene un número de identidad (UID) y puede pertenecer a uno o más grupos (GID).

`/etc/passwd · /etc/group · /etc/shadow`

Dónde Linux guarda usuarios, grupos y contraseñas cifradas. Solo root puede leer /etc/shadow.

`usuario1 · analista · cris`

Los usuarios de mi caso práctico. El grupo datos permite dar el mismo permiso a varios usuarios a la vez.

Permisos de archivos

Cada archivo define qué puede hacer su propietario, su grupo y todos los demás: leer (r = 4), escribir (w = 2) y ejecutar (x = 1).

Propietario · root

6

`rw-`

4 + 2: lee y escribe

Grupo · datos

4

`r--`

solo lee

Otros

0

`---`

sin acceso

```
chmod 640 /seguro/datos.txt
```

```
chown root:datos /seguro/datos.txt
```

Modo 640 en mi trabajo: usuario1 no accede y analista solo puede leer.

Control de acceso por roles (RBAC)

Los permisos se asignan a roles, no a personas: el usuario los obtiene al pertenecer al rol.



`Rol`

Si alguien cambia de función, solo se le cambia el rol: no hay que reconfigurar todo.



`Grupo datos`

En mi trabajo, datos funciona como rol de lector: analista hereda la lectura por pertenecer al grupo.



`SELinux · AppArmor`

Linux no trae RBAC completo: se aproxima con grupos y sudoers. SELinux y AppArmor (activo en Debian) controlan aún más.

sudo y setuid

El administrador (root) puede todo: estos mecanismos entregan ese poder de forma controlada.



`sudo`

Un usuario autorizado ejecuta un comando puntual como administrador. Pide contraseña y queda registrado.



`/etc/sudoers · grupo sudo`

Define quién puede usar sudo. En mi caso: cris sí puede y usuario1 es rechazado.



`setuid (-rwsr-xr-x)`

El programa corre con los privilegios de su dueño. Ejemplo: passwd modifica /etc/shadow, que solo root puede escribir.

Auditoría con auditd

Prevenir no alcanza: hay que detectar y dejar evidencia de quién intentó qué, y cuándo.

`auditd`

Servicio que registra los eventos de seguridad del sistema.

```
auditctl -w /seguro/datos.txt -p rwxa -k acceso_datos
```

Carga la regla: -w archivo vigilado · -p tipos de acceso (r, w, x, a) · -k clave para buscarla.

```
ausearch -k acceso_datos -i
```

Consulta los eventos: quién, qué comando, sobre qué archivo, a qué hora y si fue permitido o denegado.